Guía Maestra de Defensa Oral y Banco de Preguntas Técnicas Imprevistas

Asignatura: Tecnología Web I (SIS-0150) — Proyecto Socioformativo (Trabajo Final Integrador)

Evaluador Titular: M.Sc. Ing. Jimmy Nataniel Requena Llorentty

Institución: Universidad Privada Domingo Savio (UPDS), Santa Cruz de la Sierra

Equipo Estudiantil:

1. Ketfer Gianella Salazar
2. Charles Yourdan Conde
3. Brian Calás
4. Marco Barriga
5. Adaniel Balderrama Orellana

Estructura de la Defensa (15 Minutos en Vivo):

- **Bloque 1 (2 min):** Presentación del Colegio Bautista Boliviano Brasileño (CBBB) y diagnóstico de sus problemas reales.
- **Bloque 2 (3 min):** Arquitectura híbrida, topología de 7 nodos y las 5 decisiones técnicas clave.
- **Bloque 3 (5 min):** Demostración en vivo en terminal (Vistas DNS, validación DNSSEC con `delv`, HTTPS TLS 1.3, correo con `dkim=pass`, Fail2ban y respaldos Restic).
- **Bloque 4 (2 min):** Reconstrucción en vivo de un nodo al azar con scripts idempotentes.
- **Bloque 5 (3 min):** Ronda de preguntas técnicas imprevistas del docente.

🎯 Banco de Preguntas Técnicas Imprevistas con Respuestas Rigurosas

Pregunta 1: ¿Cómo garantizamos en BIND 9 que la vista externa jamás revele los nombres internos (`cbbb.internal`) a un atacante en internet?

- **Respuesta Técnica:**

La separación se logra mediante la directiva `match-clients` evaluada en orden estricto dentro de `/etc/bind/named.conf.local`:

```
view "interna" {
    match-clients { 127.0.0.0/8; 10.10.10.0/24; };
    zone "cbbb.internal" { ... };
    zone "10.10.10.in-addr.arpa" { ... };
};

view "externa" {
    match-clients { any; };
    zone "cbbb.example" { ... };
};
```

Cuando un cliente con IP externa (`172.30.0.100`) realiza una consulta sobre `www.cbbb.internal`, BIND 9 evalúa las ACLs: al no pertenecer a `10.10.10.0/24`, la petición cae en la vista `externa`. Dado que la zona `cbbb.internal` **no existe dentro de la vista externa**, BIND 9 responde taxativamente con el código **`REFUSED` o `NXDOMAIN`**, impidiendo que ningún atacante externo conozca las direcciones IP privadas o la existencia de servidores internos.

Pregunta 2: ¿Cuál es la diferencia entre RRSIG, DNSKEY, DS y el ancla de confianza en la validación DNSSEC con `delv`?

- **Respuesta Técnica:**

DNSSEC (RFC 4033/4034/4035) construye una cadena criptográfica de confianza jerárquica:

1. **`DNSKEY`:** Contiene las claves públicas de la zona. Se divide en la **ZSK** (*Zone Signing Key*, con la que se firman los registros de recursos como A, MX, TXT) y la **KSK** (*Key Signing Key*, con la que se firma exclusivamente el conjunto DNSKEY).
2. **`RRSIG`:** Es la firma digital matemática adjunta a cada conjunto de registros (RRset) calculada con la clave privada de BIND 9.
3. *`DS` (*Delegation Signer*):** Es el resumen criptográfico (hash SHA-256) de la clave KSK que se entrega y publica en la zona padre (en nuestro caso, NIC Bolivia en `.bo`). Vincula la delegación de nombres con la criptografía.
4. *Ancla de Confianza (*Trust Anchor*): Es la clave pública preinstalada en el validador (`delv` o Unbound) que sirve de raíz de confianza inmutable. `delv` desciende desde el ancla, verifica que el hash del DS coincida con la DNSKEY de `cbbb.example` y que el RRSIG valide el registro A, certificando el estado `fully validated`**.

Pregunta 3: ¿Por qué es un error grave activar la recursión en el mismo servidor BIND autoritativo y qué ventajas aporta el resolutor Unbound?

- **Respuesta Técnica:**

Mezclar autoridad y recursión en el mismo servidor expone a la institución a:

- *Ataques de Envenenamiento de Caché (*Kaminsky Attack*):** Un atacante puede inyectar respuestas falsas en la caché recursiva si el software no aplica aleatorización estricta de puertos y transacciones.
- **Ataques de Amplificación DNS (DDoS):** Los servidores abiertos con recursión son secuestrados por botnets para saturar a terceros enviando consultas con IP origen spoofeadas.

Ventajas de Unbound: Desacopla la función recursiva. Unbound opera solo para la red interna (`10.10.10.4`), valida DNSSEC en memoria, canaliza las consultas hacia el exterior mediante **DNS sobre TLS (DoT en puerto 853)** impidiendo que el ISP espíe la navegación escolar, y aplica filtrado de reputación mediante **RPZ**, bloqueando dominios de malware antes de que lleguen a las computadoras de los estudiantes.

Pregunta 4: Si un atacante envía un correo con `From: direccion@cbautistabb.edu.bo` desde un servidor externo, ¿cómo lo neutraliza nuestra arquitectura?

- **Respuesta Técnica:**

La defensa opera en dos niveles complementarios:

1. **A Nivel DNS con la Tríada Criptográfica (Receptores Externos):**

- El receptor (ej. Gmail) consulta el registro SPF: al ver que la IP del atacante no es el MX autorizado y que la política termina en **`-all` (HardFail)**, califica `Received-SPF: Fail`.
- El atacante no posee la clave privada RSA 2048 de OpenDKIM, por lo que no puede generar una firma válida (`dkim=fail`).
- Al evaluar **DMARC (`p=quarantine; adkim=s; aspf=s`)**, el receptor detecta que el dominio visible `From:` no alinea con SPF ni DKIM, y envía el correo directamente a la carpeta de spam o lo descarta.

2. **A Nivel Interno (Envíos Locales en Postfix):**

- Si un usuario autenticado en la red interna intenta enviar como el Director, Postfix aplica:

`-o smtpd_sender_restrictions=reject_sender_login_mismatch` con la tabla PCRE. Postfix compara el usuario SASL autenticado con el `MAIL FROM` y **aborta la sesión SMTP inmediatamente con código `553 5.7.1`**.

Pregunta 5: ¿Por qué la raíz del chroot en SFTP debe pertenecer estrictamente a `root:root (755)`?

- **Respuesta Técnica:**

OpenSSH implementa esta verificación con `stat()` en el kernel como mecanismo de defensa contra **escapes de la jaula (*chroot escape*)**:

- Si el directorio raíz de la jaula (`/srv/cbbb`) o cualquiera de sus rutas ascendentes tuviera permisos de escritura para el usuario o su grupo (ej. `webadmin`), un usuario conectado por SFTP podría renombrar el directorio, sustituir binarios o librerías dinámicas (`ld.so`), o crear enlaces simbólicos para vulnerar el aislamiento y acceder al sistema de archivos raíz (`/`) del anfitrión.
- Al forzar `root:root` con permisos máximos `755`, OpenSSH garantiza que el usuario confinado no pueda alterar la estructura base de su entorno carcelario. La escritura para el personal se habilita únicamente dentro de subdirectorios específicos (como `/srv/cbbb/www`) con máscara `0002` y propiedad compartida con el bit `setgid`.

Pregunta 6: ¿Cómo funciona el desafío DNS-01 de Let's Encrypt frente a HTTP-01 y por qué usamos `nsupdate` con TSIG?

- **Respuesta Técnica:**
- El desafío HTTP-01 obliga a levantar un servidor web en el puerto 80 accesible desde todo internet, lo cual es inviable e inseguro para servidores que residen en IPs privadas o detrás de cortafuegos.
- El **desafío DNS-01 (RFC 8555)** no requiere abrir ningún puerto web. El cliente ACME calcula un token hash criptográfico y solicita inyectarlo como un registro temporal **`_acme-challenge.dominio TXT`** en el servidor DNS autoritativo.
- Para automatizar esta inyección de forma segura sin intervención humana ni reinicios de BIND 9, se utiliza **`nsupdate` con el estándar RFC 2136**, autenticado mediante una firma criptográfica simétrica **TSIG (HMAC-SHA256)**. Let's Encrypt consulta a `ns1`, verifica el hash y emite el certificado TLS 1.3 válido, incluyendo certificados comodín (*Wildcard* `*.cbautistabb.edu.bo`).

Pregunta 7: Si el docente nos pide reconstruir un nodo en vivo (ej. `servidor-web` o `ns1`), ¿cuál es el procedimiento exacto?

- **Respuesta Técnica:**

Gracias al diseño de **infraestructura como código y scripts idempotentes**:

1. Si se destruye el contenedor: `docker rm -f servidor-web`.
2. Se recrea instantáneamente mediante Docker Compose: `docker compose up -d servidor-web`.
3. Se ejecuta el script maestro de aprovisionamiento desatendido:

```
docker exec -it servidor-web bash /root/instalar_servicios_cbbb.sh
```

4. El script instala Nginx, PHP-FPM, certificados de la CA institucional, aplica el archivo de configuración endurecido, levanta UFW, activa Fail2ban y configura el servicio systemd en menos de **90 segundos**.
5. Se valida el funcionamiento con: `bash /lab/lab15/auditar_infraestructura.sh`, certificando que todos los checks vuelven a estar en verde.

Pregunta 8: ¿Cómo garantiza Restic que un respaldo robado no comprometa las notas o datos privados de los estudiantes?

- **Respuesta Técnica:**

Restic implementa un modelo de **confianza cero y cifrado extremo a extremo en origen**:

- Antes de escribir cualquier fragmento al almacenamiento local o en la nube, los datos son fragmentados mediante un algoritmo de particionamiento de contenido (*Content-Defined Chunking* con Rabin Fingerprints).
- Cada bloque es deduplicado, comprimido y cifrado inmediatamente en la memoria RAM utilizando **AES-256 en modo GCM** (o ChaCha20-Poly1305) y firmado con **Poly1305** para integridad.

- Las claves maestras se derivan con una función de derivación de claves computacionalmente costosa contra ataques de fuerza bruta (**scrypt**).
- Si un atacante extrae el disco de respaldo o accede al repositorio en la nube, solo verá bloques blob binarios cifrados indistinguibles de ruido estocástico; sin la clave maestra, es matemáticamente imposible reconstruir un solo archivo.